



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:





Introducción al marco legal en ciberseguridad

Módulo 1

Introducción

- La ciberseguridad ya no es solo una cuestión técnica: se ha convertido en un asunto **estratégico, legal y regulatorio**. Los gobiernos y organismos internacionales han desarrollado un **conjunto creciente de leyes, directivas y estándares** para proteger tanto a los ciudadanos como a las infraestructuras críticas frente a amenazas digitales.
- En el ámbito europeo, destacan marcos como el **Reglamento General de Protección de Datos (GDPR)**, que garantiza los derechos sobre la información personal, y la **Directiva NIS2**, que establece requisitos de ciberseguridad para operadores esenciales e importantes. Estos textos imponen **obligaciones claras de prevención, detección, respuesta y notificación de incidentes**.
- En España, el **Esquema Nacional de Seguridad (ENS)** y la **Ley de Protección de Infraestructuras Críticas (Ley 8/2011)** complementan este entorno normativo, adaptando las exigencias europeas a la realidad nacional.
- Para las organizaciones, especialmente aquellas con entornos OT (tecnología operacional), cumplir con estas normativas no solo reduce el riesgo legal, sino que refuerza la resiliencia y continuidad del negocio. En un mundo cada vez más interconectado, **conocer y aplicar el marco legal en ciberseguridad es tan esencial como la tecnología misma**.

IT vs OT: ¿Cual es la diferencia?

Mientras **IT protege la información**, **OT protege procesos físicos industriales**.

En ciberseguridad OT, lo esencial es mantener la **operación segura y continua**, ya que un fallo puede tener **impactos reales en personas, medioambiente y producción**.

Aspecto	IT (Information Technology)	OT (Operational Technology)
Propósito	Gestión de datos, procesos administrativos y usuarios	Control de procesos físicos e industriales en tiempo real
Ejemplos	ERP, correo, bases de datos, redes corporativas	PLCs, SCADA, DCS, sensores, maquinaria automatizada
Prioridad de seguridad	Confidencialidad > Integridad > Disponibilidad	Disponibilidad > Integridad > Confidencialidad
Entornos típicos	Oficinas, CPDs, redes empresariales	Fábricas, plantas químicas, redes eléctricas, refinerías
Riesgos comunes	Pérdida de datos, ransomware, phishing	Paradas de planta, sabotaje físico, fallo de control

Diferencias IT vs OT en el plano normativo

Aspecto	Entorno IT	Entorno OT
Objetivo principal	Protección de datos e información	Protección de procesos físicos y continuidad operativa
Prioridades de seguridad	Confidencialidad > Integridad > Disponibilidad	Disponibilidad > Integridad > Confidencialidad
Normativas principales	GDPR, NIS2, ISO 27001, ENS, LOPDGDD	NIS2, IEC 62443, Ley PIC, CER, sectoriales OT
Supervisión habitual	AEPD, INCIBE, CCN-CERT	CNPIC, operadores críticos, CSIRTs sectoriales
Regulación de proveedores	Seguridad lógica y protección de datos	Seguridad física y digital (integrada)
Ciclo de vida tecnológico	Rápido, actualizable frecuentemente	Lento, sistemas “legacy” y restricciones operativas
Auditorías normativas	ISO 27001, ENS, protección de datos	IEC 62443, Ley PIC, seguridad industrial
Impacto de incidentes	Pérdida de datos, sanciones, reputación	Paradas de planta, daños físicos, riesgos a personas

Diferencias generales entre IT y OT

- Asunciones que son válidas en IT pueden no serlo en OT (ejemplo: periodicidad de la gestión de actualizaciones de software)
- La ciberseguridad en OT debe tener en cuenta cuestiones como el “safety” que trata de la seguridad de las personas, cosa que en IT normalmente no es un tema que se contemple

Requisitos de ejecución	IT	OT
	Tiempo de respuesta tiene que ser confiable	Tiempo de respuesta es crítico
	Retrasos son admisibles	Retrasos son un gran problema
	Poca interacción ante eventos críticos	Respuesta a emergencias es crítica
	Alto volumen de datos	Bajo volumen de datos

Requisitos de Disponibilidad	IT	OT
	Operaciones programadas	Operaciones continuas
	Fallos operacionales tolerados	Fallos no tolerados
	Reiniciar está tolerado	Reiniciar puede no estar tolerado
	Cambios con poca gestión posibles	Cambios pueden implicar recertificaciones

Diferencias generales entre IT y OT

Entornos Operativos	IT	OT	Gestión de Riesgos	IT	OT
	Aplicaciones ofimáticas	Aplicaciones de control industrial		Confidencialidad, Integridad son claves	Safety y Disponibilidad es lo que realmente importa
	Sistemas Operativos standard	Standard + propietarios		Posible impacto de pérdida de datos o retraso en las operaciones	Posible impacto de pérdida de vidas, equipamiento o producto
	Actualizaciones fáciles de implementar	Actualizaciones muy complicadas o imposibles		Se puede recuperar reiniciando la mayoría de las veces	Tener sistemas tolerantes a fallos es esencial
	Ciclo de vida del software 3-5 años	Sistemas "legacy" 15-20 años			

- No quiere decir que haya que descartar todas las tecnologías de ciberseguridad para IT y comenzar de cero.
- Pueden utilizarse tecnologías de ciber de IT en OT, pero respetando los principios de OT y adaptando las tecnologías y procedimientos a dichos principios.

Estrategia de ciberseguridad de la Unión Europea

La **Unión Europea** ha adoptado un enfoque cada vez más **estratégico y normativo** frente a las amenazas digitales, reconociendo que la ciberseguridad es un **elemento clave para la estabilidad económica, la soberanía digital y la protección de los ciudadanos**.

Su marco regulador se basa en una **estrategia de ciberseguridad común**, articulada desde 2013 y reforzada en 2020, que persigue tres grandes objetivos:

- **Construir resiliencia colectiva en toda la UE**
- **Reforzar la cooperación entre Estados miembros y con el sector privado**
- **Proteger mejor las infraestructuras críticas, datos y servicios digitales esenciales**

Para lograrlo, la UE ha desarrollado una **arquitectura normativa sólida** que abarca distintas dimensiones de la ciberseguridad:

- **Directiva NIS2 (2022/2555)**: mejora la seguridad de redes y sistemas de información para sectores esenciales e importantes.

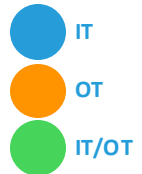
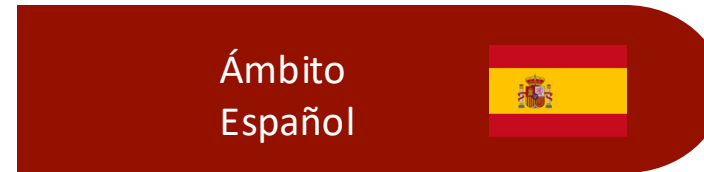
Estrategia de ciberseguridad de la Unión Europea

- **Reglamento GDPR (2016/679)**: protege la privacidad y seguridad de los datos personales.
- **Directiva CER (2022/2557)**: refuerza la resiliencia de entidades críticas ante todo tipo de amenazas, incluidas las cibernéticas.
- **Cyber Resilience Act (en proceso)**: establecerá requisitos mínimos de ciberseguridad para productos con componentes digitales.
- **Digital Operational Resilience Act (DORA)**: para el sector financiero, regula la gestión de riesgos TIC.

Este marco está respaldado por entidades como **ENISA** (Agencia Europea de Ciberseguridad), que proporciona guía técnica, formación y apoyo a los países miembros, así como por mecanismos de cooperación como los **CSIRTs europeos**.

En resumen, la estrategia de la UE no solo busca imponer obligaciones legales, sino **fomentar una cultura de ciberseguridad proactiva y coordinada** en todos los niveles: público, privado, nacional y europeo.

Normativas principales Europeas / Españolas por dominio



- GDPR**
General Data Protection Regulation
- NIS2**
Network and Information Security v2
- CRA**
Cyber Resilience Act
- DORA**
Digital Operational Resilience Act
- Normativas sectoriales UE**

- LOPDGDD**
Ley Orgánica de Protección de Datos Personales y garantía de los derechos digitales
- Ley PIC**
Protección de Infraestructuras Críticas
- Directrices del CNPIC**
Centro Nacional de Protección de Infraestructuras Críticas
- ENS**
Esquema Nacional de Seguridad

Visión general: NIS2



Directiva sobre seguridad de redes y sistemas de información (UE 2022/2555)

NIS2 es la evolución de la primera directiva NIS (2016) y refuerza las obligaciones en materia de ciberseguridad para entidades esenciales e importantes. Aplica tanto a operadores de infraestructuras críticas como a sectores industriales y digitales clave.

Puntos clave:

- Cubre sectores como energía, transporte, agua, salud, industria química, alimentación, etc.
- Requiere medidas técnicas y organizativas para gestionar riesgos cibernéticos.
- Establece plazos estrictos de notificación de incidentes (24/72 horas).
- Impone responsabilidad directa a la alta dirección.
- Obliga a auditorías, gobernanza y formación continua.

Sanciones: hasta 10 millones € o el 2% del volumen de negocio.

Vigencia: transposición nacional antes del 17 de octubre de 2024.



Visión general: DORA



Reglamento de Resiliencia Operativa Digital en el sector financiero (UE 2022/2554)

DORA aplica a todo el ecosistema financiero europeo: bancos, aseguradoras, gestoras, bolsas y también proveedores TIC que los soportan. No solo se centra en ciberseguridad, sino en garantizar la resiliencia operativa digital total.

Puntos clave:

- Cubre riesgos TIC, continuidad, gobernanza, respuesta y pruebas.
- Exige pruebas de penetración avanzadas para entidades significativas.
- Regula la relación con proveedores externos: cloud, ciberseguridad, etc.
- Introduce la supervisión de terceros críticos por parte de autoridades financieras europeas.

Permite sanciones y limitaciones operativas si no se cumplen los requisitos.

Vigencia: aplicable a partir de enero de 2025.

Visión general: GDPR



Reglamento General de Protección de Datos (UE 2016/679)

GDPR regula el tratamiento y protección de los datos personales en toda la UE, y aunque no es exclusivo de ciberseguridad, impone obligaciones técnicas y organizativas para proteger los datos frente a accesos no autorizados o pérdidas.

Puntos clave:

- Requiere el principio de “seguridad desde el diseño”.
- Exige notificar brechas de seguridad en menos de 72h a la AEPD (o equivalente).
- Impone la figura del Delegado de Protección de Datos (DPO) en muchas organizaciones.
- Derechos clave del usuario: acceso, rectificación, supresión, portabilidad.

Sanciones: hasta 20 millones € o el 4% del volumen de negocio anual.

Ámbito: aplica a cualquier organización que procese datos personales de ciudadanos UE.

Visión general: CER



Directiva sobre la Resiliencia de Entidades Críticas (UE 2022/2557)

CER amplía el enfoque de NIS2 y regula la resiliencia global de servicios esenciales, no solo frente a amenazas digitales, sino también físicas, naturales, híbridas o terroristas.

Puntos clave:

- Se aplica a sectores como energía, transporte, salud, espacio, agua, alimentación y administración pública.
- Requiere a los Estados designar entidades críticas y realizar evaluaciones de riesgo multisectoriales.
- Las entidades críticas deben tener planes de resiliencia y continuidad.
- Impulsa la cooperación transfronteriza entre autoridades nacionales.
- Cubre amenazas no exclusivamente tecnológicas (inundaciones, sabotaje, crisis geopolíticas).

Vigencia: transposición nacional antes de 17 de octubre de 2024.

Visión general: LPIC



Legislación sobre Infraestructuras Críticas (España – Ley 8/2011 y normativa derivada)

España cuenta con una legislación específica para proteger las Infraestructuras Críticas (IC) que prestan servicios esenciales a la sociedad y economía.

Puntos clave:

- Obliga a identificar operadores críticos y sus infraestructuras.
- Requiere la elaboración de Planes de Seguridad del Operador (PSO) y Planes de Protección Específicos (PPE).
- Supervisa el cumplimiento a través del CNPIC (Centro Nacional de Protección de Infraestructuras Críticas).
- Alineada parcialmente con CER y NIS2, pero con componentes propios (físicos y estratégicos).
- Aplica a sectores como agua, energía, transportes, salud, administración, etc.

Complementos: se coordina con el ENS, la Ley de Seguridad Nacional, y directivas europeas como NIS2 y CER.

Normativas Sectoriales de Ciberseguridad



ENERGÍA

◆ REMIT (Reglamento UE 1227/2011)

Regula la integridad y transparencia del mercado energético mayorista. Incluye obligaciones de reporte de incidentes que puedan afectar precios y operaciones.

◆ Red Eléctrica de España – Requisitos Específicos OT

Requiere que los agentes conectados a la red cumplan con medidas específicas de ciberseguridad en sus sistemas de control.

TRANSPORTE

◆ Reglamento 2021/796 (ERA – Ferrocarril)

Exige medidas de ciberseguridad en operadores ferroviarios europeos. Requiere evaluaciones de riesgo y coordinación con CSIRTs nacionales.

◆ Reglamento de la Agencia Europea de Aviación (EASA)

Introduce obligaciones de ciberseguridad para fabricantes, aerolíneas y proveedores de servicios.

Enfocado en seguridad operacional y tecnológica.

◆ IMO/ISM (Sector Marítimo)

Requiere que los buques implementen medidas de ciberseguridad en sus sistemas de navegación y operación. Normativa obligatoria desde 2021.

AUTOMOCIÓN

◆ TISAX (Trusted Information Security Assessment Exchange)

Esquema de evaluación de seguridad usado por grandes fabricantes. Basado en ISO/IEC 27001 + controles VDA ISA.

Obliga a proveedores a cumplir con niveles de seguridad adecuados.

◆ UN R155 & R156 (UNECE)

Regulación obligatoria para vehículos conectados: ciberseguridad (R155) y gestión de software (R156).

Requiere a fabricantes establecer procesos de detección, respuesta y parcheo.

SANIDAD

◆ NIS2 + GDPR (combinación sectorial)

El sector salud está explícitamente cubierto por NIS2 como “esencial”.

Además, GDPR regula el tratamiento de datos sensibles (historias clínicas).

◆ Regulación MDR (Medical Devices Regulation)

Dispositivos médicos conectados deben tener controles de ciberseguridad como parte del diseño y evaluación de conformidad.

Normativas Sectoriales de Ciberseguridad



TELECOMUNICACIONES

- ◆ Directiva EECC (European Electronic Communications Code)
Exige a operadores de telecomunicaciones medidas de seguridad y notificación de incidentes.
Complementada por NIS2.

INDUSTRIA MANUFACTURERA

- ◆ NIS2 + IEC 62443 (de facto)
Aunque no existe una ley específica, NIS2 incluye a fabricantes industriales “críticos” como entidades esenciales o importantes.
Se recomienda usar IEC 62443 como marco técnico de referencia.

AGUA

- ◆ Transposición nacional de NIS2 + normativa técnica local (ej. Canal de Isabel II)
Empresas gestoras de agua están dentro de NIS2. Algunas comunidades autónomas o entes reguladores imponen requisitos adicionales.

SECTOR FINANCIERO

- ◆ DORA (Reglamento UE 2022/2554)
Regula la resiliencia operativa digital de entidades financieras (bancos, seguros, fintech, etc.). Exige gestión de riesgos TIC, notificación de incidentes, pruebas de penetración y control sobre proveedores críticos.
- ◆ PSD2 (Directiva de Servicios de Pago)
Exige autenticación fuerte, cifrado y protección de las transacciones electrónicas. Impacta especialmente en bancos y fintech.
- ◆ EBA Guidelines (GL/2019/04)
Directrices de la Autoridad Bancaria Europea sobre gestión del riesgo TIC y seguridad en pagos. Aplica a bancos y entidades de crédito.

Autoridades Europeas de Ciberseguridad



◆ **ENISA (Agencia de Ciberseguridad de la Unión Europea)**

Coordina políticas de ciberseguridad en la UE.

Apoya a los Estados miembros en la implementación de NIS2, CRA y CER.

Proporciona guías, buenas prácticas y análisis de riesgos.

◆ **Comisión Europea – DG CONNECT / DG HOME**

DG CONNECT lidera el marco regulatorio de ciberseguridad (CRA, NIS2).

DG HOME supervisa aspectos de seguridad física y resiliencia crítica (CER).

Supervisan y proponen regulaciones, con poderes de control en casos transfronterizos.

Autoridades Españolas de Ciberseguridad



◆ INCIBE (Instituto Nacional de Ciberseguridad)

- Ejecuta políticas de ciberseguridad en el ámbito civil.
- Asiste a empresas, ciudadanos y operadores esenciales en IT y OT.
- Gestiona el CERT de referencia para el sector privado y ciudadanía.

◆ CNPIC (Centro Nacional para la Protección de las Infraestructuras Críticas)

- Coordina la aplicación de la Ley PIC en operadores críticos.
- Supervisa planes de seguridad específicos y medidas de protección OT.
- Dependiente del Ministerio del Interior.

◆ CCN-CERT (Centro Criptológico Nacional – CERT)

- Responsable de la ciberseguridad en el sector público.
- Elabora normativas técnicas (guías STIC, ENS).
- Supervisa incidentes y cumplimiento en organismos públicos y entidades clave.

◆ Agencia Española de Protección de Datos (AEPD)

- Supervisa el cumplimiento del GDPR y LOPDGDD.
- Tiene competencias sancionadoras en protección de datos personales.
- Publica guías sobre ciberseguridad aplicada a privacidad.



Con la colaboración:



Otras autoridades nacionales europeas de Ciberseguridad

FR ANSSI – CERT-FR

- Agence nationale de la sécurité des systèmes d'information
- Supervisa la ciberseguridad del Estado y de operadores esenciales.
 - Tiene autoridad sobre infraestructuras críticas y administra el CERT-FR (gobierno).

DE BSI – CERT-Bund

- Bundesamt für Sicherheit in der Informationstechnik
- Agencia Federal de Ciberseguridad alemana.
 - CERT-Bund es su unidad de respuesta a incidentes para infraestructuras críticas y sector público.

IT ACN – CSIRT Italia

- Agenzia per la Cybersicurezza Nazionale
- Agencia Nacional de Ciberseguridad italiana.
 - Administra el CSIRT-Italia y coordina a nivel nacional incidentes y normativa.

NL NCSC-NL

- Nationaal Cyber Security Centrum
- Depende del Ministerio de Justicia y Seguridad.
 - Coordina la ciberseguridad nacional, incluyendo infraestructuras críticas y gobierno.

Nota didáctica

Muchos países tienen un CSIRT nacional y otro especializado en gobierno/defensa, como en el caso español con CCN-CERT (gubernamental) y INCIBE-CERT (civil/empresas).

Casos reales de incumplimiento

WannaCry en hospitales
Impacto en OT

Colonial Pipeline
fallo OT+IT → sanciones y caos logístico

Multa GDPR récord a Meta
(1.200 M€)

Sanciones por incumplir **ENS** en
administraciones públicas

Caso práctico

La empresa ficticia **TechPlant S.A.** opera una planta industrial con sistemas IT (oficinas, correo electrónico, ERP) y sistemas OT (líneas de producción automatizadas, SCADA). La planta procesa datos de clientes, tiene contratos con el sector público y pertenece a un sector designado como infraestructura crítica.

Ejercicio

1. Identificar al menos **tres normas o marcos legales** que aplican a TechPlant S.A. y justificar por qué.
2. Identificar qué activos de la empresa estarían regulados por cada una de esas normas.
3. Proponer dos evidencias que la empresa debería tener preparadas para demostrar cumplimiento en una auditoría.

Caso práctico – Solución sugerida

✓ Normas o marcos legales que aplican:

- **GDPR:** porque procesa datos personales de clientes y empleados.
- **ENS (Esquema Nacional de Seguridad):** porque tiene contratos con el sector público.
- **Ley PIC / NIS2:** porque pertenece a un sector designado como infraestructura crítica.

✓ Activos regulados:

- GDPR: bases de datos de clientes, sistemas de RRHH.
- ENS: servidores que alojan aplicaciones para el sector público.
- Ley PIC / NIS2: sistemas OT que controlan la producción.

✓ Evidencias a preparar:

- Políticas y procedimientos de protección de datos documentados.
- Registros de mantenimiento y auditorías de los sistemas críticos.

Resumen del módulo

- ✓ Ciberseguridad: obligación legal, no solo técnica.
 - ✓ IT y OT tienen riesgos y obligaciones distintas.
 - ✓ Europa y los estados miembros han creado normas específicas.
-
- ✓ Cumplir = entender, implantar, evidenciar.

Cuestionario del módulo 1

- **Pregunta 1: ¿Qué norma regula la protección de datos personales?**
 - A) NIS2
 - B) GDPR
 - C) ENS
 - D) Ley PIC
- **Pregunta 2: ¿Cuál de estos es un ejemplo de infraestructura crítica?**
 - A) Página web personal
 - B) Planta de tratamiento de agua
 - C) Cuenta de redes sociales
 - D) Blog corporativo
- **Pregunta 3: En OT, la prioridad habitual es:**
 - A) Confidencialidad
 - B) Integridad
 - C) Disponibilidad y seguridad física
 - D) Anonimato

Cuestionario del módulo 1

- **Pregunta 4: ¿Qué organismo europeo apoya a los Estados miembros en temas de ciberseguridad?**
 - A) INCIBE
 - B) ENISA
 - C) ANSSI
 - D) CCN-CERT
- **Pregunta 5: ¿Qué significa cumplir con un standard o regulación?**
 - A) Tener un firewall instalado
 - B) Evitar auditorías
 - C) Implementar medidas, mantener evidencias y estar listo para auditorías
 - D) Solo aplicar en IT

Cuestionario del módulo 1 - Respuestas

- Pregunta 1: B) GDPR
- Pregunta 2: B) Planta de tratamiento de agua
- Pregunta 3: C) Disponibilidad y seguridad física
- Pregunta 4: B) ENISA
- Pregunta 5: C) Implementar medidas, mantener evidencias y estar listo para auditorías